

Stoquify Internal Activation Gate Blocker Closure and Next-Stage Execution Prompt

Date: 2026-07-24

Scope: Agent Runtime Phase 2 controlled-pilot trust gates

Target decision: `READY FOR CONTROLLED INTERNAL PILOT` or evidence-based `NO-GO`

Act as a multidisciplinary principal review team: system architect, cyber-security architect, senior frontend engineer, UI/UX specialist, product strategist, business logic analyst, and SaaS growth advisor.

Act as a senior enterprise agent-runtime and release-assurance architecture team:

- Senior enterprise software architect: preserve agent-runtime boundaries, service ownership, dependency order, platform modularity, and integration contracts.
- Structural UI/UX design expert: verify the Command Agent as a workflow-first, role-aware, accessible surface backed by service-owned read models and explicit state contracts.
- Cybersecurity and RBAC specialist: enforce tenant isolation, RBAC, module entitlement, fresh authentication, separation of duties, audit trails, redaction, secure secret handling, and safe failure behavior.
- AI governance specialist: keep the Command Agent deterministic, evidence-backed, explainable, read-only, fail-closed, and unable to exercise business authority.
- DevSecOps and SRE lead: design deployable scheduling, managed identity or secret rotation, alert delivery, acknowledgement, escalation, dead-letter recovery, observability, rollback, and evidence retention.
- PostgreSQL and Prisma specialist: preserve additive migration safety, tenant-scoped persistence, optimistic concurrency, idempotency, immutable evidence, and controlled schema deployment.
- Playwright and release-certification lead: prove authenticated desktop/mobile behavior, negative authorization paths, degradation behavior, accessibility, replay safety, and protected-data non-mutation.
- Product rollout and support operations lead: require real approvers, accountable owners, pilot support coverage, escalation routes, rollback ownership, and a separately authorized activation ceremony.
- Enterprise finance and controls expert: ensure agents cannot post ledgers, execute payments, file statutory returns, change payroll, mutate stock, approve transactions, alter close evidence, or change permissions.
- OHADA/SYSCOHADA-aware platform architect: keep statutory, accounting, country-pack, tax, payroll, and regulatory decisions outside agent authority and tied to expert-reviewed source systems.

1. Authoritative Inputs

Inspect and reconcile, in this order:

1. `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_PHASE_2A_RELEASE_CONTROL_HARDENING_EXECUTION_REPORT_2026-07-24.md`
2. `docs/agents-runtime/STOQUIFY_INTERNAL_ACTIVATION_GATE_REMEDIATION_AND_CONTROLLED_PILOT_READINESS_EXECUTION_REPORT_2026-07-24.md`
3. `what-next/agents-runtime/STOQUIFY_INTERNAL_ACTIVATION_GATE_UNBLOCKING_ANALYSIS_AND_EXECUTION_PLAN_2026-07-23.md`
4. `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_PHASED_EXECUTION_REFINED_PROMPT_2026-07-22.md`
5. `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_PRACTICAL_EXECUTION_PLAN_2026-07-22.md`
6. Current repository code, migrations, CI configuration, tests, generated evidence, and `git status`
7. Relevant architecture evidence in `graphify-out/`

The current repository is the source of truth when an older report describes a gap that has since been implemented. Record every such superseded finding.

2. Primary Objective

Determine exactly what remains blocked, solve every safely repository-addressable blocker, and produce a technically executable closure plan for the human, security, deployment, and operational blockers that cannot be truthfully completed inside the repository.

The work must position Stoquify to move from:

READY FOR REMEDIATION VERIFICATION

to:

READY FOR CONTROLLED INTERNAL PILOT

Do not activate a tenant, expose the agent to users, or authorize Phase 3 during this run. Activation is a separate high-risk decision that may occur only after all gates have independently passed and the authorized decision-makers explicitly approve it.

3. Non-Negotiable Authority Boundary

The agent runtime, its skills, tools, workers, and test harnesses must never receive:

- Direct Prisma write access to business truth
- Direct ledger posting authority
- Payment initiation or execution authority
- Statutory filing authority
- Payroll calculation, approval, salary-change, destination-change, or payment authority
- Stock adjustment, transfer, write-off, or valuation authority
- Close certification or evidence mutation authority
- Role, permission, entitlement, or organization-membership authority
- Product approval, security approval, or self-activation authority

All business changes must remain behind Stoquify-owned protected actions, domain services, RBAC, fresh-auth, maker-checker, audit, and workflow-assurance boundaries.

4. Current Blocker Set to Revalidate

Revalidate these gates instead of assuming their status:

1. Source and credential hygiene after unsafe raw browser evidence was discovered
2. Complete repository controls, including retirement, alert exhaustion, replay, and protected-data non-mutation
3. Clean-commit CI certification bound to an exact Git SHA and manifest hash
4. Real product and security approvals from distinct authorized identities
5. Named rollout, rollback, support, pilot, security-incident, and on-call backup owners
6. A deployed five-minute reconciliation schedule with managed authentication
7. Production-like alert delivery, acknowledgement, retry, dead-letter, and escalation evidence
8. Complete enabled-pilot negative, degradation, accessibility, and rollback certification
9. A final independent enterprise release-gate decision

Classify each gate as:

- PASSED
- PASSED LOCALLY
- PARTIAL
- BLOCKED - REPOSITORY
- BLOCKED - HUMAN AUTHORITY
- BLOCKED - DEPLOYMENT
- BLOCKED - EXTERNAL SERVICE
- NOT APPLICABLE

Never treat test fixtures, E2E identities, dry-run provisioning, local environment variables, or inferred names as real approval or production evidence.

5. Required Execution Workstreams

Workstream A: Evidence and Source Hygiene

1. Confirm that no raw Playwright report containing environment data remains.
2. Confirm durable browser evidence contains no secret, password, token, authorization header, database URL, auth state, or environment block.
3. Identify which non-test credentials could have been present during the unsafe local run without printing their values.
4. Produce a mandatory rotation register for the security owner:
 - Secret purpose
 - Secret-manager reference
 - Rotation owner
 - Rotation timestamp
 - Old-version revocation timestamp
 - Dependent workload restart
 - Post-rotation verification
5. Fail the gate until real rotation evidence is recorded for every potentially exposed non-test credential.

Workstream B: Repository Completion

Inspect the current implementation and complete only genuine remaining gaps in:

- Governed `SUSPENDED -> RETIRED` transition
- Append-only retirement audit evidence
- Alert retry jitter, terminal `DEAD_LETTER`, terminal-state deduplication, and recovery runbook
- Browser certification fingerprint of protected business tables before and after the enabled-pilot run
- Feedback persistence and idempotent replay evidence
- Keyboard and accessibility assertions
- Unauthorized tenant, unauthorized role, missing permission, disabled module, DRAFT definition, manifest mismatch, suspension, rollback, stale/partial/empty data, timeout, retry, and replay scenarios
- Explicit proof that the permitted persistence surface is limited to agent runs, feedback, release evidence, Workflow Assurance, and audit records

Use the least code that closes a proven gap. Preserve dirty-worktree safety and do not refactor unrelated files or clean unrelated lint warnings.

Workstream C: Clean-Commit Certification

1. Remove temporary generation artifacts and unsafe local evidence.
2. Review all intended runtime, migration, CI, test, and documentation changes.
3. Create a reviewed commit on a controlled branch.
4. Run the mandatory CI workflow from that exact commit.
5. Bind the certification record to:
 - Git commit SHA
 - Release version
 - Full agent manifest hash
 - Prompt, schema, tool, and skill versions
 - Migration set
 - Sanitized Playwright report SHA-256
 - CI run identifier and immutable artifact URL
6. Treat any evidence produced from an uncommitted or changed tree as provisional.

Do not create a commit, push, merge, or deploy unless the user has separately authorized that action.

Workstream D: Real Governance Closure

Provide the exact workflow for two independent decisions:

- Product approval
- Security approval

Require:

- Distinct active organization users
- Appropriate permissions
- Fresh authentication
- Exact manifest match
- Recorded decision, rationale, residual-risk acceptance, validity period, and audit event
- No self-approval by the release preparer where separation of duties applies

Provide the exact completion register for:

- Rollout owner
- Rollback owner
- Support owner
- Pilot owner
- Security-incident owner
- On-call backup

Each assignment must include a real directory identity, primary/backup distinction, coverage window, escalation reference, runbook version, acknowledgement, and validity period.

Do not fabricate names or mark this work complete on behalf of humans.

Workstream E: Production-Like Deployment and Scheduling

Design the minimum provider-neutral deployment contract for an isolated, production-like non-production environment:

- Deploy the exact reviewed commit
- Apply additive Prisma migrations through the release pipeline

- Configure `STOQUIFY_AGENT_RELEASE_ENVIRONMENT`
- Configure `STOQUIFY_AGENT_RECONCILER_SECRET` from a managed secret or use workload identity through an approved adapter
- Configure reconciliation policy with bounded limits
- Schedule `POST /api/internal/agents/reconcile-abandoned` every five minutes
- Send `Authorization: Bearer <managed value>` without logging the value
- Set request timeout, retry, overlap prevention, and observable correlation IDs
- Prove at least three consecutive successful scheduled windows
- Prove an unauthorized request returns `401`
- Prove missing server configuration returns `503`
- Prove stale heartbeat and manifest drift create Workflow Assurance evidence and block or suspend rollout

Prefer workload identity when supported. If a bearer secret is required, define dual-version overlap, rotation, revocation, and audit procedures.

Workstream F: Alert Transport and Operational Ownership

Configure a production-like HTTPS endpoint using managed configuration:

- `STOQUIFY_ASSURANCE_ALERT_WEBHOOK_URL`
- `STOQUIFY_ASSURANCE_ALERT_WEBHOOK_SECRET`

Verify:

- HTTPS enforcement in production mode
- Minimum secret strength
- Idempotency key behavior
- Successful delivery and stored external reference
- Owner acknowledgement linked to the incident
- Retry with bounded exponential backoff and jitter
- Fifth-attempt terminal dead-letter behavior
- Duplicate queue events do not resurrect delivered or dead-letter records
- Escalation when acknowledgement SLO expires
- Recovery and replay from dead-letter require an authorized operator and an audit reason

The alert gate passes only when a named owner acknowledges a real production-like test incident and escalation evidence is retained.

Workstream G: Full Enabled-Pilot Certification

Run authenticated desktop and mobile certification against PostgreSQL and protected actions.

Required positive evidence:

- Command Agent surface loads for the authorized pilot role
- Evidence-backed daily brief renders
- Evidence links resolve to tenant-authorized routes
- Feedback persists
- Replay returns the existing receipt without duplicate execution
- Agent run, feedback, Workflow Assurance, release, and audit evidence persist

Required negative and degradation evidence:

- Cross-tenant denial

- Unauthorized role denial
- Missing permission denial
- Module-entitlement denial
- DRAFT or missing definition denial
- Manifest mismatch denial
- Kill-switch denial
- Suspended-release denial
- Expired approval or owner coverage denial
- Stale heartbeat and unhealthy alert transport denial
- Empty, partial, stale, and unavailable source data remain explicitly qualified
- Timeout, retry, replay, and concurrent duplicate behavior
- Rollback or suspension takes effect without changing global definitions
- Keyboard operation and automated accessibility checks
- No horizontal overflow at desktop and mobile sizes
- Protected business-data fingerprint is identical before and after

Sanitize the durable Playwright report before hashing or certification. Delete raw reporter output before certification and fail if forbidden keys survive.

Workstream H: Independent Enterprise Release Gate

After all evidence is available, run `017-aqstoqflow-enterprise-release-gate` as an independent decision.

The gate must issue one of:

- `GO - READY FOR CONTROLLED INTERNAL PILOT`
- `CONDITIONAL GO - NAMED, TIME-BOUND CONDITIONS`
- `NO-GO - BLOCKERS REMAIN`

The gate must not convert missing human, deployment, or external-service evidence into an assumption.

6. Exact Verification Baseline

Run the applicable focused and release commands from the reviewed commit:

```
npm run prisma:validate
npm run prisma:migration:safety:gate
npm run prisma:migrate:deploy
npm run prisma:migrate:status
npm run typecheck
npm run agent:runtime:gates
npm run agent:release-control:postgres-smoke
npx jest services/agents services/assurance/__tests__/assurance-alert-delivery.service.test.ts
components/agents --runInBand
npm run test:e2e:command-agent:enabled
npm run verify:ci
git diff --check
```

Add deployment checks for:

- Scheduler invocation and heartbeat
- Unauthorized and unconfigured reconciler responses

- Webhook delivery, retry, dead-letter, acknowledgement, and escalation
- Secret rotation
- Exact Git SHA and image/deployment digest

Capture exit codes, timestamps, environment name, commit SHA, manifest hash, report hashes, CI run identifier, and unresolved warnings. Never capture secret values.

7. Required Evidence Bundle

Produce an evidence index containing:

- Release package ID and state
- Organization and environment identifiers
- Git SHA and deployment digest
- Manifest and schema hashes
- Migration status
- Product and security decision record IDs
- Owner assignment and acknowledgement record IDs
- Reconciliation check-run, finding, incident, and heartbeat IDs
- Alert delivery, acknowledgement, escalation, and dead-letter test IDs
- Playwright certification ID and sanitized report hash
- Protected-data before/after fingerprint version and hashes
- CI run and immutable artifact references
- Credential-rotation evidence references
- Rollback drill evidence
- Enterprise release-gate decision

The evidence index may contain identifiers and safe references, never credentials or personal contact data.

8. Required Report

Save the result as:

- docs/agents-runtime/STOQUIFY_INTERNAL_ACTIVATION_GATE_BLOCKER_CLOSURE_AND_NEXT_STAGE_EXECUTION_REPORT_2026-07-24.md
- docs/agents-runtime/STOQUIFY_INTERNAL_ACTIVATION_GATE_BLOCKER_CLOSURE_AND_NEXT_STAGE_EXECUTION_REPORT_2026-07-24.pdf

The report must include:

1. Executive decision
2. Revalidated current state
3. Superseded findings
4. Blocker-by-blocker solution matrix
5. Architecture and trust-boundary assessment
6. Exact technical implementation and deployment procedure
7. Governance and ownership completion procedure
8. Security and credential response
9. Scheduler and secret-rotation design
10. Alert acknowledgement, escalation, and dead-letter design

11. Browser certification matrix
12. Verification commands and evidence requirements
13. Rollback and emergency-disable plan
14. Sequenced execution roadmap with dependencies
15. RACI and human completion register
16. Residual risks
17. Final gate decision and next authorized action

Clearly distinguish what has been implemented, locally verified, externally verified, formally approved, deployed, certified, and activated.

9. Stop Conditions

Stop and issue **NO-GO** if any of these occurs:

- Tenant isolation failure
- Any protected business-data mutation caused by the agent
- Direct business or release authority available to the agent
- Missing or bypassable RBAC, fresh-auth, or separation-of-duties controls
- Manifest or certification mismatch
- Unrotated potentially exposed non-test credential
- Missing real product or security decision
- Missing owner coverage
- Reconciliation heartbeat outside policy
- Unhealthy alert transport or unacknowledged critical incident
- Unsanitized browser evidence
- Failed mandatory test, migration, runtime gate, or clean-commit CI job
- Activation attempted before a separately authorized decision

10. Success Criteria

This prompt is successfully executed only when:

1. Every blocker has a named owner, closure method, evidence requirement, and pass/fail rule.
2. Every repository-addressable gap is either implemented and verified or explicitly documented with the exact reason it remains open.
3. Human approvals and operational ownership are recorded by real authorized people, never simulated.
4. Scheduler, secret rotation, alert delivery, acknowledgement, escalation, and dead-letter behavior are demonstrated in an isolated production-like environment.
5. The complete enabled-pilot matrix passes from a clean commit.
6. Protected business data is unchanged by the certification run.
7. The independent enterprise release gate issues a documented decision.
8. No tenant is activated during this execution.

11. Non-Goals

- Do not start Phase 3 agents.
- Do not activate production or a real pilot tenant.

- Do not add another agent framework.
- Do not introduce autonomous business writes.
- Do not replace Stoquify's Workflow Assurance incident spine.
- Do not fabricate approvals, owners, secrets, deployments, or evidence.
- Do not weaken a gate to obtain a passing status.
- Do not refactor unrelated application code.

12. Final Decision Rule

If repository work is complete but real governance or production-like deployment evidence is absent, the correct result is:

NO-GO - READY FOR CONTROLLED REMEDIATION VERIFICATION

Only when every required technical, human, security, deployment, and certification artifact exists may the result become:

GO - READY FOR CONTROLLED INTERNAL PILOT

Even then, activation requires a separate explicit authorization.